

Đặng Huy Hoán

MSV : 2351170595

Nhiệm vụ Thực hành (BẮT BUỘC)

Kịch bản: Xây dựng một trang "Danh sách sinh viên" đơn giản.

Trang này cho phép bạn:

1. Thêm sinh viên mới vào CSDL (Dùng INSERT).
2. Hiển thị toàn bộ sinh viên đang có trong CSDL (Dùng SELECT).

A. Thiết lập Ban đầu (Bắt buộc)

1. Mở phpMyAdmin.
2. Tạo một CSDL mới tên là cse485\_web.
3. Chọn CSDL cse485\_web, mở tab SQL và chạy lệnh sau để tạo bảng:

```
SQL CREATE TABLE sinhvien ( id INT AUTO_INCREMENT PRIMARY KEY, ten_sinh_vien  
VARCHAR(255) NOT NULL, email VARCHAR(255) NOT NULL, ngay_tao TIMESTAMP DEFAULT  
CURRENT_TIMESTAMP );
```

B. Code Khởi đầu (Starter Code):

Tạo 1 tệp chapter4.php trong thư mục htdocs của XAMPP:

PHP

```
<!DOCTYPE html>
```

```
<html lang="vi">
```

```
<head>
```

```
    <meta charset="UTF-8">
```

```
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
```

```
    <title>Chương 4 - Website Hướng Dẫn Liệu</title>
```

```
    <style>
```

```
        body { font-family: Arial, sans-serif; margin: 40px; }
```

```
        table { width: 100%; border-collapse: collapse; margin-top: 20px; }
```

```
        th, td { border: 1px solid #ccc; padding: 10px; text-align: left; }
```

```

    th { background-color: #f2f2f2; }

    .form-group { margin-bottom: 15px; }

    input[type="text"], input[type="email"] { width: 300px; padding: 8px; }

    input[type="submit"] { padding: 10px 20px; background: #007cba; color: white; border: none;
cursor: pointer; }

</style>

</head>

<body>

<?php
// === KẾT NỐI CSDL DÙNG PDO ===

$host = '127.0.0.1';    // <-- ĐỔI THÀNH 127.0.0.1 (KHÔNG DÙNG localhost nữa)

$port = 3307;          // <-- CỔNG MẶC ĐỊNH CỦA XAMPP LÀ 3307

$db  = 'cse485_web';

$user = 'root';    // mặc định

$pass = '';        // mặc định để trống

$charset = 'utf8mb4';

$dsn = "mysql:host=$host;port=$port;dbname=$db;charset=$charset";

try {

    $pdo = new PDO($dsn, $user, $pass);

    $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

} catch (PDOException $e) {

    die("Kết nối thất bại: " . $e->getMessage());

}

```

```
// === THÊM SINH VIÊN ===

if (isset($_POST['ten_sinh_vien']) && isset($_POST['email'])) {
    $ten = trim($_POST['ten_sinh_vien']);
    $email = trim($_POST['email']);

    $sql = "INSERT INTO sinhvien (ten_sinh_vien, email) VALUES (?, ?)";
    $stmt = $pdo->prepare($sql);
    $stmt->execute([$ten, $email]);

    header('Location: chapter4.php');
    exit;
}
```

```
// === LẤY DANH SÁCH ===

$sql_select = "SELECT * FROM sinhvien ORDER BY ngay_tao DESC";
$stmt_select = $pdo->query($sql_select);
?>
```

```
<h1>Thêm Sinh Viên Mới (Chủ đề 4.3)</h1>
<form method="POST" action="chapter4.php">
    <div class="form-group">
        <label>Tên sinh viên:</label><br>
        <input type="text" name="ten_sinh_vien" required>
    </div>
    <div class="form-group">
```

```
<label>Email:</label><br>
<input type="email" name="email" required>
</div>
<input type="submit" value="Thêm">
</form>
```

```
<h1>Danh Sách Sinh Viên (Chủ đề 4.2)</h1>
```

```
<?php if ($stmt_select->rowCount() == 0): ?>
```

```
<p>Chưa có sinh viên nào.</p>
```

```
<?php else: ?>
```

```
<table>
```

```
<thead>
```

```
<tr>
```

```
<th>ID</th>
```

```
<th>Tên Sinh Viên</th>
```

```
<th>Email</th>
```

```
<th>Ngày Tạo</th>
```

```
</tr>
```

```
</thead>
```

```
<tbody>
```

```
<?php while ($row = $stmt_select->fetch(PDO::FETCH_ASSOC)): ?>
```

```
<tr>
```

```
<td><?= htmlspecialchars($row['id']) ?></td>
```

```
<td><?= htmlspecialchars($row['ten_sinh_vien']) ?></td>
```

```
<td><?= htmlspecialchars($row['email']) ?></td>
```

```

<td><?= htmlspecialchars($row['ngay_tao']) ?></td>

</tr>

<?php endwhile; ?>

</tbody>

</table>

<?php endif; ?>

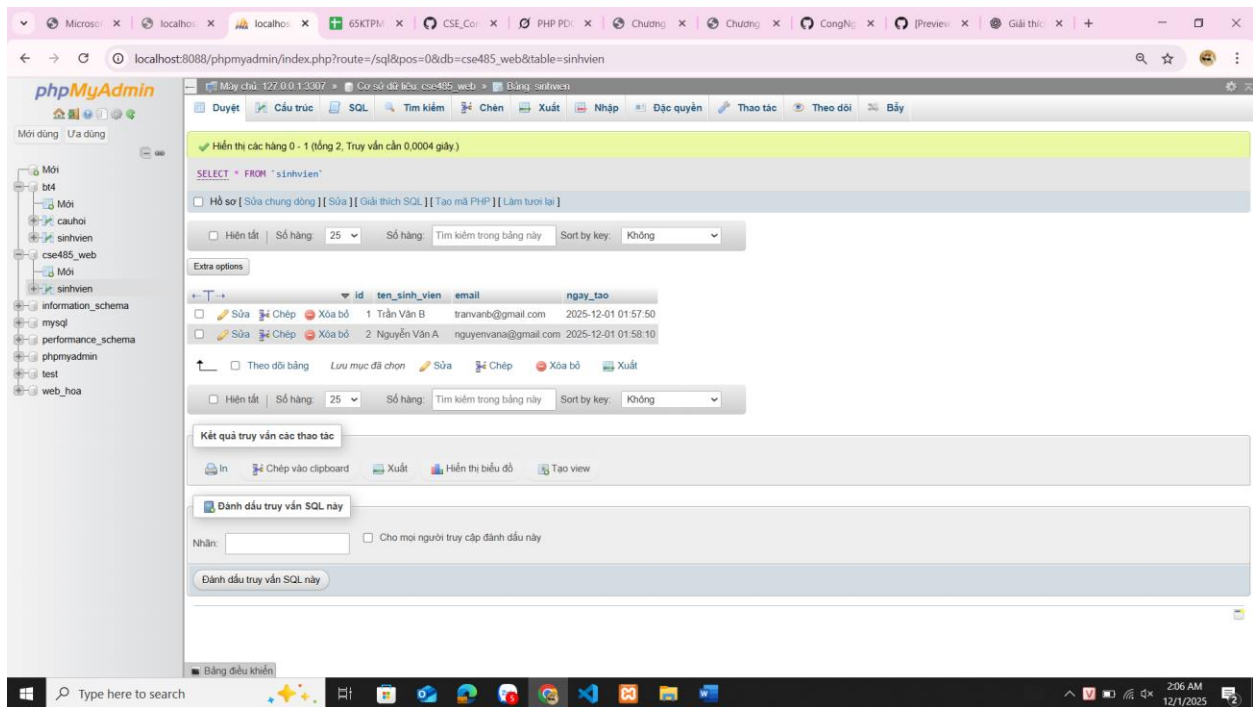
</body>

</html>

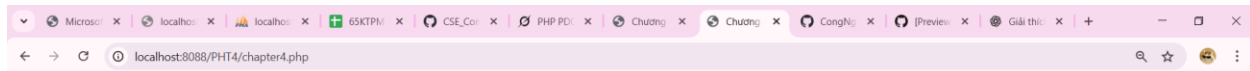
```

B. Ảnh chụp màn hình Kết quả (BẮT BUỘC CẢ 2 ẢNH):

1. Ảnh 1 (phpMyAdmin): Chụp màn hình tab "Browse" (Duyệt) của bảng sinhvien trong phpMyAdmin, cho thấy bạn đã INSERT thành công ít nhất 2-3 sinh viên.



2. Ảnh 2 (Trình duyệt Web): Chụp ảnh màn hình trang chapter4.php của bạn, hiển thị đúng 2-3 sinh viên mà bạn vừa thêm (chứng minh SELECT thành công).



### Thêm Sinh Viên Mới (Chủ đề 4.3)

Tên sinh viên:

Email:

[Thêm](#)

### Danh Sách Sinh Viên (Chủ đề 4.2)

| ID | Tên Sinh Viên | Email                | Ngày Tạo            |
|----|---------------|----------------------|---------------------|
| 2  | Nguyễn Văn A  | nguyenvana@gmail.com | 2025-12-01 01:58:10 |
| 1  | Trần Văn B    | tranvanb@gmail.com   | 2025-12-01 01:57:50 |



## 4. Câu hỏi Phản biện (Bắt buộc)

Nếu không dùng Prepared Statements mà nối chuỗi trực tiếp trong lệnh INSERT, hãy đưa ra một ví dụ cụ thể về giá trị nhập vào ô “Tên sinh viên” và “Email” để có thể thực hiện tấn công SQL Injection, ví dụ: xóa toàn bộ dữ liệu hoặc drop bảng sinhvien. Giải thích ngắn gọn tại sao cách này nguy hiểm

## 5 . Kết nối Đánh giá (Rất quan trọng)

Kỹ năng kết nối CSDL bằng PDO (bao gồm INSERT và SELECT) là kỹ năng quan trọng nhất trong khối kiến thức PHP thuần.

Bạn sẽ vận dụng trực tiếp PHT này để hoàn thành Bài tập trên lớp (Phần PHP), chiếm 20% tổng điểm, dự kiến vào Tuần 5. Nắm vững PDO bây giờ cũng sẽ giúp bạn hiểu tại sao Eloquent ORM (Chương 8) lại mạnh mẽ và tiện lợi đến vậy.